

AI Audit Report — HW06 API Testing (§9, phụ lục bắt buộc)

- **Sinh viên:** Lê Nhựt Duy — **MSSV:** 23127178
- **AI Policy của bài:** Open — **bắt buộc** có lời khai + audit đầy đủ. §17: thiếu tài liệu bắt buộc = 0 điểm.

I use AI tools for the following tasks.

Công cụ đã dùng (§8)

Công cụ	Việc
Claude Code (Opus 5)	chọn API, sinh test case, audit, viết collection Postman, tooling, báo cáo
Postman + Newman	thực thi test case, xuất HTML report
(bổ sung nếu dùng thêm)	

Cách đọc file này

Mỗi lượt hỏi AI = một mục `Interaction #N`, ghi đủ 5 trường §9 (tool · ngày giờ · prompt nguyên văn · output · human review) cộng 3 trường riêng của HW06 (bước trong quy trình · AI sai/bỏ sót · vì sao bỏ sót). Ba trường sau chép thẳng được sang §11 của `report/main-report.md`.

Nhãn human review dùng đúng hai giá trị, **không** viết gộp thành "đã kiểm hết": - **(SV đã kiểm)** — sinh viên đã tự chạy lại / đối chiếu spec / đối chiếu source. - **(SV chưa tự kiểm)** — chưa kiểm, giữ nguyên để trung thực.

Interaction #1

- **API / Bước:** chọn API cho 3 pool (trước §6.1)
- **Bước trong quy trình:** chọn phạm vi — §5
- **AI tool:** Claude Code (Opus 5)
- **Date & time:** 2026-08-18 23:17
- **Prompt:** (ảnh chụp 4 bộ API các bạn đã chọn) + "những cái trên là cái api mà bạn tui nó chọn. bạn hãy dựa vào yêu cầu đề bài chọn cho tui các api khác đi" + file đề 2026.HW06.API Testing_En.pdf
- **AI output (tóm tắt):** đọc đề + `api_specification.md` + `backend/server.js`, đối chiếu 4 bộ API đã bị lấy, đề xuất bộ 3 chưa ai chọn: `GET /api/products` (A/FR-05) · `POST /api/cart` (B/FR-07) · `PUT /api/products/:id` (C/FR-15), kèm giả thuyết bug rút từ source (SQL nối chuỗi ở :143, không validate ở :290, thiếu `authenticateToken` ở :179) và 2 phương án dự phòng.
- **AI sai / bỏ sót:** (chưa đánh giá — bộ API mới chỉ là đề xuất, chưa chạy request nào để xác nhận các giả thuyết bug)

- **Vì sao bỏ sót:** —
- **Human review: (SV chưa tự kiểm)** — cần (1) xác nhận với nhóm là 4 bộ kia đúng như ảnh chat, (2) tự gửi request kiểm từng giả thuyết bug trước khi viết vào bug report.
- **Commit:** —

Interaction #2

- **API / Bước:** dựng khung repo + tooling (trước §6.1)
- **Bước trong quy trình:** setup
- **AI tool:** Claude Code (Opus 5)
- **Date & time:** 2026-08-18 23:30
- **Prompt:** rùi bây giờ bạn hãy tham khảo HW01, HW02 làm giúp tui do hai bài đó có điểm. hãy setup trước trong repo /Users/mac0s/Documents/HK3_Nam3/kiem_thu/HW06-API-Testing
- **AI output (tóm tắt):** đọc quy ước HW01/HW02/HW05, dựng khung HW06: cấu trúc thư mục theo §14, docs/api-selection.md (bảng chứng §5), tooling (`preflight · seed-api-data · run-newman · summarize-newman · ci-gate · tc2xlsx · build-pdfs · verify-all · package · commit-plan`), environment + pre-request script Postman, workflow GitHub Actions, 4 Agent Skill, và các file template rỗng, mỗi file đánh dấu rõ trạng thái *chưa hoàn thành* để một bản dở dang không thể trông như đã xong (`verify-all.sh` và `package.sh` fail khi dấu đó còn).
- **AI sai / bỏ sót:** ghi 2 file vào thư mục HW05 do lỗi thư mục làm việc, đã phát hiện và chuyển về HW06 + hoàn nguyên HW05.
- **Vì sao bỏ sót:** đặc điểm công cụ (shell giữ cwd giữa các lệnh) — không phải giới hạn của model.
- **Human review: (SV chưa tự kiểm)** — cần chạy `npm run preflight` với SUT đang chạy để xác nhận tooling hoạt động thật, và đọc lại docs/api-selection.md trước khi chốt với nhóm.
- **Commit:** (điền hash sau khi commit)

Interaction #3

- **API / Bước:** cả 3 API — kiểm chứng giả thuyết bug trước khi thiết kế test case
- **Bước trong quy trình:** api-test-design bước 1 (rút ràng buộc) — phần đối chiếu hành vi thật
- **AI tool:** Claude Code (Opus 5)
- **Date & time:** 2026-08-18 23:55
- **Prompt:** rùi bạn hãy làm toàn bộ những j bạn có thể làm đi rùi nói tui (lượt này là bước đầu tiên AI tự chia: viết script probe gửi ~60 request thật để kiểm 12 giả thuyết bug rút từ đọc source, TRƯỚC khi viết test case — để expected không dựa trên suy đoán)
- **AI output (tóm tắt):** script `probe.mjs` + `probe2.mjs` gửi request thật cho cả 3 API. Kết quả: xác nhận SQLi (`' OR '1'='1` → toàn bộ bảng), lỗi DB trả HTML kèm `SQLITE_ERROR`, `GET /api/products/:id` không tồn tại → 200 {}, `price` là **string** khi id chẵn, `POST /api/cart` nhận mọi input sai, giờ **không** xóa sau checkout, `PUT/POST/DELETE /api/products` **không cần token**, partial update ghi NULL đè. Phát hiện **ngoài dự kiến:** SUT **chết giữa lúc probe** — chuỗi `PUT-không-token` → `price NULL` → `GET id chẵn` → `row.price.toString()` trên null → `TypeError` không bắt → tiến trình node kết thúc (**BUG-14**).
- **AI sai / bỏ sót:** —
- **Vì sao bỏ sót:** —
- **Human review: (SV chưa tự kiểm)** — cần chạy lại `bash bug-report/verify-bugs.sh` và tự đọc log; đặc biệt kiểm BUG-14 vì nó là bug nặng nhất của bài.
- **Commit:** (điền hash)

Interaction #4

- **API / Bước:** API-01 · API-02 · API-03 — sinh test case
- **Bước trong quy trình:** api-test-design bước 1→5 (mỗi API một lượt, mỗi bước một mục trong file spec)
- **AI tool:** Claude Code (Opus 5)
- **Date & time:** 2026-08-19 00:05
- **Prompt:** (cùng lượt #3 — AI tự chia thành các bước theo skill `api-test-design`)
- **AI output (tóm tắt):** 3 file `generator/specs/*.mjs` định nghĩa **136 test case** (109 AI + 22 SV + 24 setup/teardown) theo 4 nhóm §6.1, kèm cột **Căn cứ** cho từng case; và `tools/gen-artifacts.mjs` sinh ra bảng Markdown 12 cột + collection Postman từ cùng nguồn.
- **AI sai / bỏ sót:** 1. **Bịa expected** ở 3 case chỗ spec im lặng: TC-PRODLIST-011 (`search=" "` → "0 dòng"), TC-CART-008 ("vượt tồn kho" — bảng không có cột tồn kho), TC-PRODUPD-005 (`name 300` ký tự → 400). 2. **Sinh mã JS lỗi cú pháp:** tên `pm.test` chứa giá trị chuỗi không escape dấu `"` → 2 case đỏ với `missing )` after argument list (không phải bug SUT). 3. Ban đầu định đặt chuỗi làm sập SUT (BUG-14) **vào trong collection** — sẽ làm mọi case sau đỏ vì môi trường.
- **Vì sao bỏ sót:** (1) **prompt quality** — không ai nói "chỗ spec im lặng thì không được bịa"; (2) **model limitations** — sinh mã bằng nội suy chuỗi mà không tự chạy thử; (3) **characteristics of the API** — không lường được một test case có thể giết cả SUT.
- **Human review: (SV chưa tự kiểm)** — 3 case bịa expected đã được sửa và ghi trong `audit.md` của từng API; lỗi cú pháp đã sửa trong generator; BUG-14 đã tách ra `verify-bugs.sh`. **Sinh viên cần tự đọc lại 3 file `audit.md`** và tự chạy 2–3 case bằng curl để xác nhận expected đúng.
- **Commit:** (điền hash)

Interaction #5

- **API / Bước:** cả 3 API — audit (§6.2) + thêm case AI bỏ sót (§6.3)
- **Bước trong quy trình:** api-test-audit
- **AI tool:** Claude Code (Opus 5)
- **Date & time:** 2026-08-19 00:10
- **Prompt:** (cùng lượt — bước audit chạy riêng sau bước sinh, không gộp)
- **AI output (tóm tắt):** dán nhãn 109 case AI (**106 VALID · 3 INCOMPLETE đã sửa**), viết 3 mục `auditNotes`, và thêm **22 case sinh viên** với bảng "vì sao AI bỏ sót" phân loại đúng 3 nhóm §6.3.
- **AI sai / bỏ sót:** đây là **AI tự audit output của chính nó** — một hạn chế phải nói rõ: nó bắt được loại lỗi *thiếu căn cứ trong spec* (vì kiểm được bằng cách đối chiếu văn bản), nhưng không có gì bảo đảm nó bắt được lỗi thuộc loại *chính nó không nghĩ tới*. Chính vì vậy 22 case §6.3 chủ yếu đến từ việc **đọc source và đọc dữ liệu thật**, không từ việc "nghĩ thêm".
- **Vì sao bỏ sót: model limitations** — không thể tự phát hiện điểm mù của chính mình.
- **Human review: (SV chưa tự kiểm)** — đây là **mục cần sinh viên can thiệp nhiều nhất**. §6.2 nói "You are fully responsible for the final test cases"; nhãn VALID hiện tại là nhãn do AI đặt.
- **Commit:** (điền hash)

Interaction #6

- **API / Bước:** cả 3 API — thực thi (§6.4)
- **Bước trong quy trình:** postman-newman
- **AI tool:** Claude Code (Opus 5)

- **Date & time:** 2026-08-19 00:24
- **Prompt:** (cùng lượt)
- **AI output (tóm tắt):** chạy 3 collection bằng Newman trên SUT thật: **171 request · 329 assertion · 240 xanh · 89 đỏ**; sinh `summary.md` tự động từ raw JSON; điền baseline cổng CI (29/30/30).
- **AI sai / bỏ sót:** lượt chạy **đầu tiên** có 4 assertion đỏ **không phải** do SUT: 2 do lỗi cú pháp JS (mục #4), 2 do seed user2 chạy trước khi SUT seed xong bảng `users` (đỏ vì môi trường). Nếu không truy nguyên, cả 4 sẽ bị báo thành bug của SUT.
- **Vì sao bỏ sót:** **characteristics of the API** — `database.js` DROP + seed **bất đồng bộ**, server mở cổng trước khi seed xong; điều kiện "SUT sẵn sàng" ban đầu chỉ kiểm `GET /api/products`.
- **Human review: (SV chưa tự kiểm)** — điều kiện sẵn sàng đã sửa thành `login admin được`; cần chạy `npm run test:all` một lượt nữa để tự thấy 29/30/30 tái lập.
- **Commit:** (điền hash)

Interaction #7

- **API / Bước:** bug report (§6.5)
- **Bước trong quy trình:** sau execution
- **AI tool:** Claude Code (Opus 5)
- **Date & time:** 2026-08-19 00:30
- **Prompt:** (cùng lượt)
- **AI output (tóm tắt):** `bug-report/verify-bugs.sh` tái hiện **19/19 bug** bằng curl (kèm chuỗi làm sập SUT và tự khởi động lại), log lưu ở `verify-bugs-output.txt`; `bug-report.md` với 19 bug + **4 giả thuyết bị loại** sau khi kiểm chứng.
- **AI sai / bỏ sót:** ban đầu script giữ pipe của tiến trình con nên lệnh gọi bị treo tới timeout — lỗi plumbing, đã sửa bằng `< /dev/null`.
- **Vì sao bỏ sót:** **model limitations** (chi tiết về fd của shell).
- **Human review: (SV chưa tự kiểm)** — cần tự chạy `bash bug-report/verify-bugs.sh` và đối chiếu log; sau đó **mở 19 GitHub Issue kèm ảnh** (§6.5 đòi, hiện chưa có).
- **Commit:** (điền hash)

Interaction #8

- **API / Bước:** báo cáo, traceability, Excel, README
- **Bước trong quy trình:** tổng hợp
- **AI tool:** Claude Code (Opus 5)
- **Date & time:** 2026-08-19 00:40
- **Prompt:** (cùng lượt)
- **AI output (tóm tắt):** `report/main-report.md` (12 mục, bảng 11 lỗi của AI), traceability matrix (phủ FR-05...FR-15 + SEC-01...SEC-07, ghi rõ 2 ô ngoài phạm vi), `excel/23127178_HW06_TestCases.xlsx`, cập nhật README + danh sách Postman feature.
- **AI sai / bỏ sót:** xuất Excel lần đầu ra **250 dòng** thay vì 136 — gộp cả `generated.md` lẫn `audit.md` nên mỗi case AI bị đếm hai lần. Phát hiện vì con số không khớp với `summary.md`.
- **Vì sao bỏ sót:** **prompt quality** — `audit.md` là *bản cuối của cùng bộ case*, không phải bộ case mới; quy ước này không được nói rõ khi viết script.
- **Human review: (SV chưa tự kiểm)** — cần đọc lại §11 và §12 của main-report (bảng lỗi AI và mục giới hạn) vì đó là hai mục dễ nhầm lẫn nhất, và tự viết lại phần nào không đồng ý.

- **Commit:** (điền hash)

Interaction #9

- **API / Bước:** cả 3 API — kiểm tính tái lập của lượt chạy
- **Bước trong quy trình:** postman-newman (sau execution)
- **AI tool:** Claude Code (Opus 5)
- **Date & time:** 2026-08-19 00:48
- **Prompt:** (cùng lượt — bước tự kiểm sau khi có kết quả)
- **AI output (tóm tắt):** chạy lại toàn bộ 3 collection để đối chiếu với lượt đã ghi vào báo cáo. API-02 ra 34 do thay vì 30. Tái hiện thủ công **3/3 lần**: `POST /api/register` trả `200 {"id":3}` rồi user biến mất khỏi `GET /api/admin/users`. Nguyên nhân: server phục vụ request bằng dữ liệu cũ trong `database.sqlite` trong lúc `DROP TABLE users` của `database.js` chưa chạy; dòng log `"Database initialized and seeded"` in ra **trước** khi SQL chạy xong. Sửa: mốc sẵn sàng = **ghi rồi kiểm chứng bản ghi còn sống** (tối đa 12 lần thử), và seed thất bại thì **chặn** lượt chạy. Sau khi sửa: **3 lượt liên tiếp đều 29/30/30**.
- **AI sai / bỏ sót:** bản sửa ở lượt #6 ("`mốc sẵn sàng = login admin được`") **chưa đủ** — nó chỉ chứng minh có một bảng `users` nào đó có dữ liệu, không chứng minh đó là bảng mới sau khi DROP.
- **Vì sao bỏ sót: characteristics of the API** — không lường được rằng file SQLite cũ vẫn phục vụ được request trong cửa sổ giữa `listen()` và `DROP TABLE`.
- **Human review: (SV chưa tự kiểm)** — chạy `npm run test:all` hai lượt liên tiếp và xác nhận cùng ra 29/30/30. Đây là mục nên tự kiểm trước khi nộp, vì nếu số liệu không tái lập thì mọi con số trong báo cáo mất giá trị.
- **Commit:** (điền hash)

Bảng tổng hợp lỗi của AI đã bắt được (điền dần)

Bảng này trùng nội dung với §11 của `report/main-report.md` — viết một lần, dùng hai chỗ.

#	Lượt	AI sai gì	Nhóm lý do	Phát hiện bằng cách nào	Đã sửa thế nào
1	#4	TC-PRODLIST-011: bị expected 0 dòng cho <code>search=""</code> (spec không nói về trim)	prompt quality	soát cột <code>Căn cứ</code> , không trở được vào mục nào của spec	hạ về 200 + schema
2	#4	TC-CART-008: expected "vượt tồn kho" nhưng bảng <code>products</code> không có cột tồn kho	prompt quality	đối chiếu <code>database.js:64-72</code>	giữ case + ghi rõ hạn chế mô hình dữ liệu
3	#4	TC-PRODUPD-005: ghi cứng 400 cho name 300 ký tự	prompt quality	soát cột <code>Căn cứ</code>	hạ về "không 500 + vẫn là JSON"
4	#5	bỏ sót phân vùng tiếng Việt chữ thường có dấu	characteristics of the API	tự thử <code>search=áo</code> bằng curl trên fixture thật	thêm TC-PRODLIST-101 → BUG-05
5	#5	coi <code>%</code> chỉ là payload SQLi, bỏ mất <code>%</code> trong dữ liệu hợp lệ	model limitations	nhìn tên fixture "bàn phím 100%"	thêm TC-102/103 → BUG-06

#	Lượt	AI sai gì	Nhóm lý do	Phát hiện bằng cách nào	Đã sửa thế nào
6	#5	test security dừng ở status code , không kiểm hệ quả	model limitations	nhận ra SUT trả 200 cho mọi thứ → status code không phân biệt được gì	thêm 6 case verify → nâng BUG-13 lên Critical
7	#5	không kiểm response lỗi (content-type, rò rỉ)	prompt quality	thấy <code>search='</code> trả 500 khi probe	thêm TC-105 → BUG-02
8	#5	chỉ kiểm endpoint được giao, bỏ route lân cận cùng nhóm quyền	prompt quality	đọc <code>server.js</code> quanh dòng 179	thêm TC-PRODUPD-107/108
9	#4 /# 6	sinh mã JS lỗi cú pháp (tên <code>pm.test</code> không escape ")	model limitations	lượt Newman đầu: <code>missing) after argument list</code>	sửa <code>fieldEq</code> trong generator
10	#6	seed user2 chạy trước khi SUT seed xong DB	characteristics of the API	SETUP-03 của API-02 đỏ 401 — đỏ vì môi trường	điều kiện sẵn sàng đổi thành <i>login admin được</i>
11	#8	xuất Excel đếm đúng case AI (250 thay vì 136)	prompt quality	số không khớp <code>summary.md</code>	bỏ <code>generated.md</code> khỏi sheet gộp khi đã có <code>audit.md</code>
12	#2	ghi 2 file vào repo HW05 thay vì HW06	đặc điểm công cụ (shell giữ cwd)	đối chiếu <code>git status</code> của HW05	chuyển file về HW06, hoàn nguyên HW05
13	#7	script giữ pipe của tiến trình con → lệnh gọi treo tới timeout	model limitations	lệnh chạy <code>verify-bugs.sh</code> bị timeout 2 phút	thêm <code>< /dev/null</code> khi khởi động SUT
14	#9	bản sửa cho lỗi #10 vẫn sai: "login admin được" không phải mốc SUT đã seed xong	characteristics of the API	chạy lại để kiểm tái lập: API-02 ra 34 thay vì 30; tái hiện thủ công 3/3 lần	mốc sẵn sàng = ghi rồi kiểm chứng bản ghi còn sống ; seed thất bại thì chặn lượt chạy
15	#8	<code>verify-all.sh</code> đếm dòng thay vì TC ID duy nhất (50 thay vì 43)	kỹ thuật	số không khớp <code>summary.md</code>	đếm <code>sort -u</code> trên TC ID

Ba lỗi đáng giá nhất về phương pháp là #9, #10 và #14 — đặc biệt #14, vì nó là **một bản sửa sai được sửa lại**: lượt chạy sau lần sửa đầu đã xanh và trông như đã xong. Chỉ có lượt **kiểm tái lập** mới lộ ra. Nguyên tắc: một bản sửa chỉ đúng khi kết quả **tái lập được**, không phải khi nó xanh một lần.

Ngoài ra — cả hai làm test case đỏ, và nếu không truy nguyên thì sẽ bị **báo thành bug của SUT**. Sau khi sửa, API-02 từ 34 assertion đỏ còn 30. Đó là lý do mỗi assertion đỏ phải trả lời được: *đỏ vì SUT sai, vì test viết sai, hay vì môi trường?*